

SFTP Security Guide

Security Guide — Threat Model, Hardening, Secrets

Revision: 1 **Last modified:** 2026-07-11T15:23:48Z

Security posture of the enterprise SFTP management system: what we defend against, how the stack is hardened, and how secrets are handled. Operator mandates: enterprise-grade, secure, easy to use — in that priority order when they conflict.

Planned mechanisms cite their work item (ATM-xxx); they are the committed design, validated only when the item closes with captured evidence.

Table of contents

1. [Threat model \(summary\)](#)
2. [Secret handling \(§11.4.10\)](#)
3. [Rootless / no-root posture](#)
4. [SFTP daemon hardening](#)
5. [API security](#)
6. [Rate limiting](#)
7. [Audit log](#)
8. [TLS / HTTPS termination](#)
9. [Hardening checklist](#)
10. [Related docs](#)

1. Threat model (summary)

Threat	Asset	Mitigation
Credential brute-force against sshd	SFTP accounts	Rate limiting (fail2ban or API-side), key-only auth option, strong password policy, chroot confinement

Threat	Asset	Mitigation
API token theft / replay	Super-admin control plane	Short-lived JWT (auth/middleware), HTTPS termination, no tokens in logs, rate-limited login
Path traversal / chroot escape	Host filesystem	ChrootDirectory %h + ForceCommand internal-sftp; homes root-owned, non-user-writable at the top; writable subdirectory per user
Data exfiltration via misconfigured public accounts	User data	public never defaults true; explicit acknowledgement required; public ⇒ read_only enforced at validation
Supply-chain / image tampering	Container images	Pinned image tags (no floating :latest in prod), rootless runtime, no privileged containers
Secret leakage into git	All credentials	.env + *.key + *.pem git-ignored (§11.4.30); pre-commit audit; chmod 600 on secret files
Container breakout affecting host	Host OS	Rootless Podman (user-namespace isolation), no sudo anywhere in ops scripts (§11.4.161)

2. Secret handling (§11.4.10)

- **Never tracked in git:** .env, .env.*, *.env (except .env.example placeholders), *.pem, *.key, id_rsa*, id_ed25519*, secrets/, DB passwords, API tokens. Enforced by .gitignore matrix (ATM-001) + pre-commit audit.
- **Permissions:** chmod 600 on credential files, chmod 700 on their parent directory.

- **Never printed:** setup and ops scripts never echo secrets; logs and audit entries carry redacted references only.
- **users.conf:** atm0z/sftp accepts encrypted password entries via the :e marker (user:\$1\$...:e:uid:gid, verified 2026-07-11). The renderer (ATM-003) writes hashes only — plaintext passwords are never rendered. Even so, treat users.conf as sensitive: `chmod 600`, host-readable only by the service user.
- **Rotation:** on any suspected leak, rotate affected credentials immediately, then record the incident. Pre-store leak audit per §11.4.10.A when the operator supplies new secret material.
- **Firebase:** optional (ATM-007); its config files are fetched by `scripts/firebase_config.sh` into git-ignored paths — never committed.

3. Rootless / no-root posture

- Everything runs in **rootless Podman** (§11.4.161): containers execute under the unprivileged service user inside a user namespace; a container root maps to an unprivileged host UID. Podman supports non-privileged-user operation natively (verified 2026-07-11, docs.podman.io).
- No sudo, no rootful Docker, no escalation anywhere in scripts/ or systemd units — units are `systemctl --user` scoped.
- Compose runs via `podman-compose`, a daemon-less script that executes podman directly and installs into `~/.local` without root (verified 2026-07-11).
- The only host-privilege touchpoint is optional `loginctl enable-linger` (survive logout); see [troubleshooting_guide.md](#) §6.

4. SFTP daemon hardening

Baseline from docs/research/mvp/MVP.md, carried into the enterprise stack (ATM-003 config system):

```
Subsystem sftp internal-sftp
Match Group sftp
    ChrootDirectory %h
    ForceCommand internal-sftp
    AllowTcpForwarding no
    PermitTTY no
    X11Forwarding no
```

- **Chroot rule (load-bearing):** for internal-sftp, the chroot directory (the user’s home, %h) must be **owned by root and not writable by the user**. Users write into a subdirectory (e.g. upload/), never into the home top-level. The atm0z README confirms the symptom: “users can’t create new files directly under their own home directory” — the provisioner

(ATM-003) creates the writable subdirectory automatically. Violating this rule makes login fail outright.

- **No shell, no forwarding:** ForceCommand internal-sftp + PermitTTY no + forwarding disabled — SFTP is the only capability.
- **Host keys persisted** (/etc/ssh/host_keys volume) so recreating the container never triggers MITM warnings for clients.
- **Key-only option:** accounts with an empty password field authenticate solely via .ssh/keys/ mounts (atmoz appends them to authorized_keys). Global PasswordAuthentication no is the recommended production end-state.

5. API security

PLANNED — STREAM-2 (ATM-002):

- Super-admin bootstrap is single-shot (second call → 409).
- Login issues short-lived JWTs; all /api/v1/** except /auth/login + /healthz requires Authorization: Bearer.
- Middleware stack: request ID, structured logging (no secret fields), recovery, authn/authz, rate limiting.
- Strict JSON schema validation on every write endpoint; unknown fields rejected (composes with the ATM-003 strict config loader).
- /healthz unauthenticated liveness; /readyz checks DB + users.conf render state.
- Bind address defaults to 127.0.0.1 unless TLS termination (§8) is configured.

6. Rate limiting

- **API:** per-IP + per-account limits on /auth/login (ATM-002, ratelimiter submodule); defaults: 5 attempts / minute / IP, exponential backoff, lockout telemetry into the audit log.
- **sshd:** host-side fail2ban jail on the mapped SFTP port is the recommended production layer (see MVP.md hardening checklist); auth-failure bursts are also visible in container logs for SIEM ingestion.
- **Chaos-tested:** rate-limit correctness under burst load is covered by the stress/chaos suites (ATM-009, §11.4.85).

7. Audit log

PLANNED — ATM-002. Append-only record of every security-relevant event: super-admin login (success/failure), account create/update/delete/disable, public enablement (with acknowledgement), permission changes, key add/remove, backup/

restore, config reloads. Each row: timestamp (UTC), actor, action, target, source IP, outcome. Queryable via GET /api/v1/audit; never contains secret material.

8. TLS / HTTPS termination

The API speaks plain HTTP internally; terminate TLS in front. Options:

1. **Reverse proxy (recommended):** Caddy / nginx / Traefik in the same rootless compose stack, terminating TLS and proxying 127.0.0.1:7722. Caddy gives automatic Let's Encrypt with minimal config.
2. **API-native TLS (PLANNED post-MVP):** load cert/key from git-ignored paths, ListenAndServeTLS.
3. **Loopback-only:** for single-host admin, keep 127.0.0.1 binding and use SSH port-forwarding from the admin workstation:

```
ssh -L 7722:127.0.0.1:7722 <host-user>@<server>
```

Never expose the API plaintext on a routable interface.

9. Hardening checklist

☐

.env chmod 600, not tracked (verify `git ls-files | grep -x .env` is empty)

☐

users.conf hash-only entries (:e marker), chmod 600

☐

SSH host keys persisted; clients see stable fingerprints

☐

ChrootDirectory %h + writable subdirectory provisioned per user

☐

Password auth disabled once keys are deployed (production end-state)

☐

API bound to loopback or behind TLS proxy; JWT TTL short

☐

Rate limiting active on /auth/login; fail2ban jail on SFTP port

☐

Zero public: true accounts unless explicitly acknowledged + audit-logged

☐

Images pinned by tag; rootless everywhere; no privileged containers



Audit log reviewed on a schedule; backups encrypted at rest

10. Related docs

- [user_management_guide.md](#) — permission model, public-guard, keys
 - [deployment_guide.md](#) — rootless deployment
 - [troubleshooting_guide.md](#) — auth/permission failure playbooks
 - [../architecture/permissions_model.md](#)
 - [docs/research/mvp/MVP.md](#) — baseline hardening checklist
-

Sources verified (2026-07-11)

- Internal: [docs/research/mvp/MVP.md](#) (sshd hardening block, chroot guidance, fail2ban note) · [docs/Issues.md](#) ATM-002/003/007 (API security, config strictness, Firebase opt-in) · [docs/CONTINUATION.md](#) (rootless-only constraint).
- External fetched this revision: <https://github.com/atmoz/sftp> (:e marker, chroot home-not-writable symptom, `.ssh/keys/` mechanism, host-key persistence recommendation) · <https://docs.podman.io/en/latest/> (non-privileged-user operation) · <https://github.com/containers/podman-compose> (daemon-less rootless install).
- OpenSSH chroot rule (`ChrootDirectory` must be root-owned, non-user-writable) is documented in `sshd_config(5)`; the [atmoz README](#) evidences the resulting symptom. To re-verify before each release (§11.4.99): `sshd_config(5)` man page, [atmoz/sftp README](#).